Day 37 – Vulnerability Assessment lab

AUTHORIZED LAB ENVIRONMENT: Tasks

STEP 1 — VERIFY NETWORK

Document your Kali IP and the target VM IP. Do not proceed unless the target is clearly your authorized lab VM.

```
msfadmin@metasploitable:~$ ifconfig eth0
eth0      Link encap:Ethernet  HWaddr 08:00:27:25:9f:b8
          inet addr:192.168.77.20  Bcast:192.168.77.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe25:9fb8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:24 errors:0 dropped:0 overruns:0 frame:0
          TX packets:32 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:8016 (7.8 KB)  TX bytes:4664 (4.5 KB)
          Base address:0xd020 Memory:f0200000-f0220000
```

```
┌──(kirthikaa㉿kali)-[~]
└─$ ip addr show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:af:ed:06 brd ff:ff:ff:ff:ff:ff
    inet 192.168.77.10/24 scope global eth0
       valid_lft forever preferred_lft forever
```

STEP 2 — HOST DISCOVERY

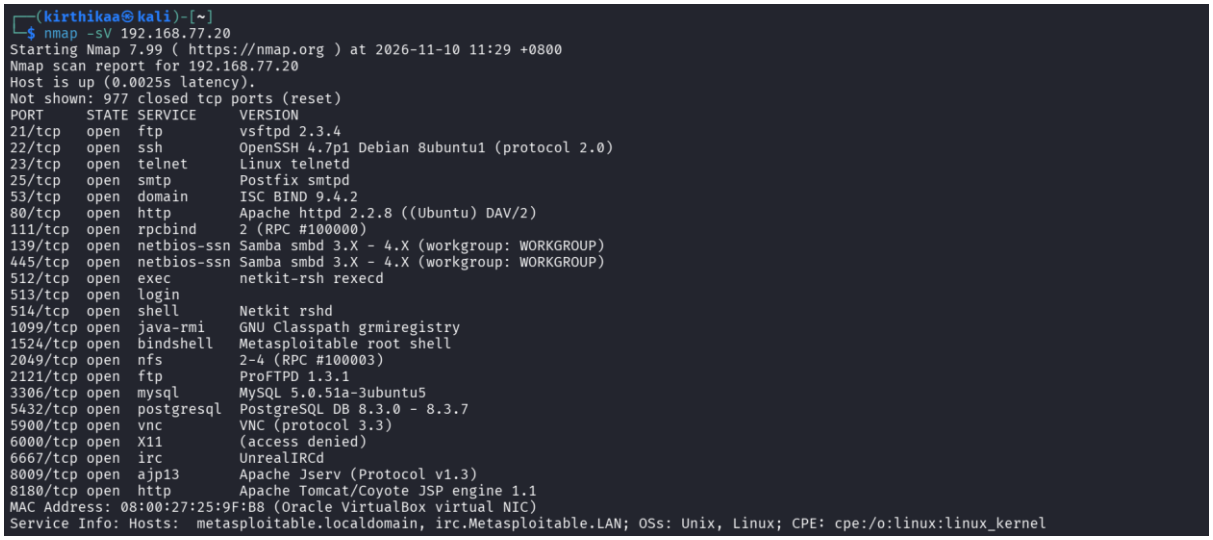
Use your previously taught Nmap discovery knowledge, e.g. nmap -sn <AUTHORIZED-LAB-SUBNET> — only against your isolated training subnet — and identify the intentionally vulnerable VM.

```
┌──(kirthikaa㉿kali)-[~]
└─$ nmap -sn 192.168.77.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-10 11:28 +0800
Nmap scan report for 192.168.77.20
Host is up (0.0018s latency).
MAC Address: 08:00:27:25:9F:B8 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds
```

STEP 3 — PORT SCAN

Perform an authorized service scan against ONLY the local training VM, e.g. nmap -sV <TARGET-LAB-IP>. Record open port, protocol, service and detected version.

Day 37 – Vulnerability Assessment lab



```
┌──(kirthikaa㉿kali)-[~]
└─$ nmap -sV 192.168.77.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-10 11:29 +0800
Nmap scan report for 192.168.77.20
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:25:9F:B8 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

STEP 4 — ASSET/SERVICE TABLE

Create the table: PORT | SERVICE | VERSION | EXPOSURE | NOTES. Example: 22 | SSH | detected version | open | remote administration service. Do NOT label every open port as vulnerable.

Port	Service	Detected version	Exposure	Notes
21	FTP	vsftpd 2.3.4	Open	File transfer
22	SSH	OpenSSH 4.7p1	Open	Remote administration
23	Telnet	Linux telnetd	Open	Remote access
25	SMTP	Postfix smtpd	Open	Email service
53	DNS	ISC BIND 9.4.2	Open	Name resolution
80	HTTP	Apache 2.2.8	Open	Web server
111	rpcbind	RPC #100000	Open	RPC service mapping
139	NetBIOS-SSN	Samba 3.X–4.X	Open	File sharing
445	NetBIOS-SSN	Samba 3.X–4.X	Open	SMB file sharing
512	exec	netkit-rsh rexecd	Open	Remote execution service
513	login	Not identified	Open	Remote login
514	shell	Netkit rshd	Open	Remote shell service

1099	Java RMI	GNU Classpath rmiregistry	Open	Java remote registry
1524	bindshell	Metasploitable root shell	Open	Unusual exposed shell
2049	NFS	RPC #100003	Open	Network file sharing
2121	FTP	ProFTPD 1.3.1	Open	File transfer
3306	MySQL	5.0.51a-3ubuntu5	Open	Database service
5432	PostgreSQL	8.3.0–8.3.7	Open	Database service
5900	VNC	Protocol 3.3	Open	Remote desktop
6000	X11	Access denied	Open	Display service
6667	IRC	UnrealIRCd	Open	IRC server
8009	AJP13	Apache JServ	Open	Application server connector
8180	HTTP	Apache Tomcat/Coyote	Open	Java web application server

STEP 5 — SELECT FINDINGS

Select at least 3 interesting exposed services for further vulnerability research. For each, record product, version and port.

Exposed Service	**FTP**	**HTTP**	**MySQL**
Product	vsftpd	Apache HTTP Server	MySQL
Version	2.3.4	2.2.8	5.0.51a-3ubuntu5
Port	Port 21	Port 80	Port 3306

STEP 6 — VULNERABILITY RESEARCH

Use NVD, vendor security advisories, CVE references and trusted security documentation to research whether the detected version may be associated with known vulnerabilities. IMPORTANT: a search result is NOT automatically a confirmed vulnerability.

Service	**CVE / issue**	**Research result**
vsftpd 2.3.4	CVE-2011-2523	Package provenance must be verified
Apache 2.2.8	End-of-life software	Unsupported; individual CVEs need applicability checks

MySQL 5.0.51a	CVE-2008-4097	Version matches; configuration conditions need checking

STEP 7 — VALIDATION

For each possible finding ask: Is the product correct? Is the version correct? Is the vulnerability applicable? Could this be a false positive? Is additional safe evidence available? Exploitation is NOT required (and not allowed).

Validation check	**Result**
MySQL installed	Yes
Version	5.0.51a-3ubuntu5
Listening port	3306/tcp
Listening process	mysqld
Listening address	0.0.0.0
mysqladmin version	Access denied for msfadmin

STEP 8 — BASIC PRIORITIZATION

Classify each finding Low / Medium / High / Critical using severity information + exposure + asset context + potential impact. Explain your reasoning for each.

Finding	**Severity**	**Reason**
FTP — Port 21	Low	Nmap banner suggests vsftpd 2.3.4, but installation and actual service identity are unconfirmed.
Apache — Port 80	Medium	Confirmed outdated Apache 2.2.8 installation with no ongoing security support.
MySQL — Port 3306	Medium	Outdated MySQL version listening on all IPv4 interfaces; specific CVE applicability remains unverified.

Day 37 – Vulnerability Assessment lab

STEP 9 — REMEDIATION

For each finding, provide a recommended patch/update, configuration improvement, service restriction or other appropriate remediation.

Finding	Recommended remediation
FTP	Identify the actual FTP daemon, remove unnecessary FTP services, or replace with a supported secure file-transfer service such as SFTP.
Apache	Upgrade Apache to a currently supported release and apply security updates.
MySQL	Upgrade MySQL to a supported release, restrict database access to trusted interfaces, and enforce strong authentication.

STEP 10 — MINI REPORT

Create the table: Finding | Severity | Affected Port/Service | Evidence | Potential Impact | Remediation | Reference. Minimum 3 findings. Close with a short executive summary.

Item	Details
Target	Metasploitable 2
Target IP	192.168.77.20
Attacker machine	Kali Linux
Network	Isolated VirtualBox lab
Scanning tool	Nmap 7.99
Assessment type	Authorized vulnerability assessment

Finding	Severity	Port / Service	Evidence	Potential impact	Remediation
FTP service identity requires verification	Low / Informational	21 / FTP	Nmap detected vsftpd 2.3.4, but local checks showed xinetd listening and	Incorrect service identification could lead to false vulnerability reports.	Identify the actual FTP daemon. Disable unnecessary FTP services or use SFTP.

Day 37 – Vulnerability Assessment lab

			vsftpd was not installed.		
Outdated Apache web server	Medium	80 / HTTP	dpkg -l apache2 and apache2 -v confirmed Apache 2.2.8.	An unsupported web server may contain known security weaknesses.	Upgrade to a supported Apache release and apply security updates.
Outdated MySQL database	Medium	3306 / MySQL	dpkg -l mysql-server confirmed 5.0.51a. netstat confirmed port 3306 listening on 0.0.0.0.	An outdated database exposed on all IPv4 interfaces increases the attack surface.	Upgrade MySQL, restrict network access and enforce strong authentication.

Summary

- An authorized vulnerability assessment was conducted against the Metasploitable 2 virtual machine using Kali Linux and Nmap.
- The target was identified at 192.168.77.20. The service scan identified several exposed services, including FTP, Apache HTTP Server and MySQL.
- Further validation confirmed that Apache 2.2.8 and MySQL 5.0.51a were installed. Both are outdated software versions that require upgrading. MySQL was also found listening on all IPv4 interfaces through port 3306.
- The FTP service identification could not be confirmed because Nmap's version detection did not match the locally installed packages and listening-process evidence.
- Recommended actions include upgrading outdated software, restricting unnecessary network services, strengthening authentication and conducting further vulnerability verification.
- The assessment was performed entirely within an isolated VirtualBox training environment. No exploitation was performed.